FYTRAC

Requisito No Funcional: RNF-02

ESPECIFICACIÓN TÉCNICA

Módulo: Seguridad & Compliance **Estado:** Aprobado **Versión:** 1.0 **Fecha:** Octubre 2026

> **1. Descripción del Requisito:**
> El sistema **Fytrac** debe garantizar la confidencialidad, integridad y disponibilidad del patrimonio e información financiera de los usuarios mediante la implementación de estándares de encriptación de grado militar (tanto en reposo como en tránsito) y la adhesión estricta al marco regulatorio de protección de datos personales y seguridad bancaria.

2. POLÍTICAS DE ENCRIPTACIÓN Y CIFRADO DE DATOS

2.1. Cifrado en Repositorio Local (Modo Offline / Dispositivo Móvil)

Para la capa offline, la seguridad de la base de datos local se estructura bajo los siguientes estándares:

- **Estándar:** Uso obligatorio de `AES-256-GCM` (Advanced Encryption Standard con Galois/Counter Mode) para el almacenamiento local del dispositivo (SQLite / Realm / IndexedDB).
- **Gestión de Claves:** La clave de cifrado local nunca se almacenará en texto plano. Se derivará mediante `PBKDF2` o `Argon2` a partir del PIN/Master Password del usuario y se custodiará en el enclave seguro del sistema operativo (**Keystore** en Android / **Keychain** en iOS).
- **Biometría:** Integración con *BiometricPrompt* / *LocalAuthentication* para desencriptar temporalmente la clave de la base de datos local durante la sesión activa.

2.2. Cifrado en Repositorio Central (Servidor PostgreSQL)

La infraestructura del servidor central aplicará cifrado multinivel para resguardar la base de datos principal:

- **Cifrado de Base de Datos (At-Rest):** Utilización de `AES-256` a nivel de volumen/disco en el almacenamiento del servidor central.
- **Cifrado a Nivel de Columna:** Los datos altamente sensibles (números de cuenta, identificadores bancarios, tokens de sincronización) se cifrarán utilizando la extensión `pgcrypto` de PostgreSQL o cifrado en capa de aplicación antes de la inserción.
- **Hashing de Credenciales:** Las contraseñas de los usuarios se almacenarán aplicando la función hash `Argon2id` o `bcrypt` (factor de costo mínimo 12).

2.3. Cifrado en Tránsito (Comunicaciones y Sincronización)

- **Protocolo de Red:** Todas las comunicaciones entre el cliente y el servidor se ejecutarán exclusivamente sobre **HTTPS** utilizando **TLS 1.3** (se rechazará cualquier conexión TLS inferior a 1.2).
- **Certificate Pinning:** La aplicación móvil implementará *SSL/TLS Pinning* para validar la clave pública del servidor central y prevenir ataques de tipo *Man-In-The-Middle* (MITM).
- **Integridad del Payload:** Toda carga útil de sincronización offline usará firmas HMAC con `SHA-256` para asegurar que los datos no hayan sido alterados antes de enviarse a la nube.

3. CUMPLIMIENTO NORMATIVO Y REGULACIÓN

3.1. Protección de Datos Personales y Privacidad

Fytrac se ajusta al marco regulatorio de protección a la vida privada (Ley 19.628 de Chile y estándares equivalentes internacionales):

- **Principio de Finalidad:** Los datos financieros se capturan única y exclusivamente para brindar los servicios de trazabilidad, presupuestos y proyecciones del usuario en Fytrac.
- **Derechos ARCO:** La plataforma dispondrá de servicios backend para que el usuario pueda ejercer de forma directa sus derechos de *Acceso, Rectificación, Cancelación y Oposición*.
- **Derecho al Olvido / Borrado Seguro:** La solicitud de eliminación de cuenta ejecutará un borrado en cascada (*purge*) de datos personales y transacciones tanto en la nube como en el dispositivo local.

3.2. Tratamiento de Información Bancaria y Transaccional

- **Aislamiento de Credenciales Bancarias:** Fytrac **no almacenará** credenciales de acceso a la banca en línea de los usuarios (claves de internet, coordenadas o contraseñas). La integración se realiza mediante OAuth 2.0 / OpenID Connect sobre APIs bancarias autorizadas.
- **Lineamientos PCI-DSS:** Fytrac **no procesa ni almacena números de tarjeta completos (PAN)** ni códigos CVV/CVC. Únicamente se almacenarán y mostrarán los últimos 4 dígitos del plástico (`last_four_digits`) para identificación visual.

3.3. Trazabilidad y Auditoría (Audit Log)

Toda modificación de presupuestos, vinculación de tarjetas y sincronización generará un registro inmutable con los datos: `user_id`, `timestamp_utc`, `tipo_evento`, `ip_origen` y `hash_integridad`. Estos registros se conservarán cifrados durante 12 meses.

4. MATRIZ DE VERIFICACIÓN DEL REQUISITO

Criterio / Área	Estándar / Mecanismo	Método de Verificación
Cifrado Local	AES-256-GCM + Android Keystore / iOS Keychain	Inspección de memoria y auditoría de archivos de base de datos locales.
Cifrado en Tránsito	TLS 1.3 + SSL Pinning en App Móvil	Análisis de tráfico de red con proxy de intercepción (Burp Suite / OWASP ZAP).
Almacenamiento Passwords	Argon2id / bcrypt (cost factor: 12)	Auditoría de código fuente en backend y revisión del esquema PostgreSQL DDL.
Manejo de Tarjetas	Enmascaramiento (solo últimos 4 dígitos)	Pruebas de penetración e inspección de respuestas JSON en endpoints API.
Cumplimiento Privacidad	Ley 19.628 + Borrado en cascada (Purge)	Prueba funcional del proceso de borrado definitivo de cuenta de usuario.